

AVANGARD SECURITY

Detail Layanan & Contoh Celah Keamanan Web

Cyber Defense untuk Aplikasi Web - dari pengujian, deteksi, hingga respons insiden.

Juni 2026 - stacopa-avangard.com

Bagian I - Detail Layanan

Enam layanan inti Avangard yang difokuskan pada keamanan aplikasi web, mencakup siklus pencegahan, deteksi, respons, dan kepatuhan.

1. VAPT & Ethical Hacking

Vulnerability Assessment & Penetration Testing

Simulasi serangan siber terkontrol terhadap aplikasi web Anda untuk mengekspos celah keamanan sebelum peretas jahat menemukannya.

- **Web Application Pentest:** Pengujian menyeluruh berbasis OWASP Top 10 (injection, XSS, broken access control, dll.).
- **API Security Testing:** Pengujian keamanan endpoint REST/GraphQL: autentikasi, otorisasi, dan rate limiting.
- **Authentication & Business Logic:** Pengujian manajemen sesi, privilege escalation, dan celah logika bisnis aplikasi.
- **Detailed Reporting:** Laporan teknis untuk tim IT dan laporan eksekutif untuk manajemen.

Metodologi: 01 Reconnaissance > 02 Scanning > 03 Exploitation > 04 Reporting

2. Managed Detection & Response (MDR)

Security Monitoring untuk Aplikasi Web & Cloud

Pemantauan keamanan berkelanjutan berbasis SIEM untuk aplikasi web dan cloud Anda. Sistem memantau otomatis sepanjang waktu, dengan analisis dan respons oleh tim ahli kami.

- **Continuous SIEM Monitoring:** Deteksi otomatis sepanjang waktu atas log aplikasi web, web server, WAF, dan cloud.
- **Expert Alert Triage:** Analisis memvalidasi alert (jam kerja + eskalasi kritis), memisahkan ancaman nyata dari false positive.
- **Threat Detection:** Identifikasi pola serangan & indikator kompromi (IoC) pada layer aplikasi & cloud.
- **Incident Response Support:** Eskalasi & pendampingan respons cepat saat insiden kritis terdeteksi.

Metodologi: 01 Log Ingestion > 02 Correlation > 03 Triage & Analysis > 04 Response

3. Incident Response

Emergency Response & Recovery

Layanan gawat darurat siber. Ketika Anda diserang ransomware atau malware, tim kami terjun langsung untuk mengisolasi, menghentikan penyebaran, dan memulihkan operasional sistem.

- **Ransomware & Malware Containment:** Isolasi cepat sistem yang terinfeksi untuk menghentikan penyebaran serangan.
- **System Recovery:** Pemulihan operasional bisnis dari backup yang bersih secara terkendali.
- **Root Cause Analysis:** Menentukan bagaimana serangan dapat terjadi untuk menutup celah penyebabnya.
- **Hardening & Post-Incident Report:** Rekomendasi perbaikan agar serangan serupa tidak terulang.

Metodologi: 01 Identification > 02 Containment > 03 Eradication > 04 Recovery

4. GRC & Compliance

Governance, Risk, and Compliance

Memastikan bisnis Anda memenuhi standar regulasi global dan nasional. Kami mendampingi dari gap analysis hingga audit readiness.

- **ISO 27001 Readiness:** Persiapan dokumen & kontrol teknis untuk sertifikasi.

- **UU PDP (Privacy Data):** Kepatuhan terhadap Undang-Undang Pelindungan Data Pribadi Indonesia.
- **IT Risk Assessment:** Identifikasi & valuasi risiko aset informasi perusahaan.
- **Policy Development:** Penyusunan SOP & Kebijakan Keamanan Informasi yang solid.

Metodologi: 01 Gap Analysis > 02 Implementation > 03 Internal Audit > 04 Certification

5. Secure Web Infrastructure

Web Hardening & Secure Deployment

Perancangan dan pengerasan infrastruktur web Anda agar aman sejak awal (security by design), dari konfigurasi web server hingga proteksi WAF dan secure deployment.

- **Web Server Hardening:** Pengerasan konfigurasi web server, OS, dan layanan mengikuti CIS Benchmark.
- **WAF & DDoS Protection:** Proteksi aplikasi web dari serangan OWASP dan trafik berbahaya pada layer aplikasi.
- **Secure Deployment & Config:** Konfigurasi hosting/cloud aman, TLS/HTTPS, manajemen secret, dan pipeline CI/CD aman.
- **Zero-Trust Access:** Penerapan prinsip never trust, always verify pada akses aplikasi & panel admin.

Metodologi: 01 Assessment > 02 Design > 03 Implementation > 04 Validation

6. Phishing Simulation & Training

Security Awareness Program

Program edukasi karyawan melalui simulasi serangan phishing nyata untuk meningkatkan kesadaran keamanan dan mengurangi risiko human error - pintu masuk serangan yang paling umum.

- **Realistic Phishing Campaign:** Simulasi email phishing terarah menyerupai serangan nyata.
- **Awareness Training:** Materi interaktif untuk mengenali & melaporkan social engineering.
- **Behavior Analytics:** Pengukuran click-rate & tingkat pelaporan untuk memetakan area berisiko.
- **Progress Reporting:** Laporan perkembangan kesadaran keamanan untuk manajemen.

Metodologi: 01 Baseline Test > 02 Simulation > 03 Training > 04 Re-assessment

Bagian II - 10 Contoh Celah Keamanan Web

Selama pengujian (VAPT), kami telah menemukan 500+ celah keamanan pada aplikasi web klien. Berikut 10 jenis celah yang paling representatif - seluruhnya mengacu pada OWASP Top 10, standar industri untuk risiko keamanan aplikasi web. Contoh bersifat ilustratif untuk edukasi.

1 SQL Injection (SQLi)

OWASP A03: Injection

Severity: Critical

- Apa itu:** Input pengguna disisipkan langsung ke query database tanpa sanitasi yang memadai.
- Contoh:** Kolom username pada form login diisi ' OR '1'='1' sehingga autentikasi terlewati.
- Dampak:** Pencurian seluruh isi database (data pelanggan, kredensial), bahkan pengambilalihan server.

2 Cross-Site Scripting (XSS)

OWASP A03: Injection

Severity: High

- Apa itu:** Aplikasi menampilkan input pengguna tanpa encoding, sehingga skrip berbahaya tereksekusi di browser korban.
- Contoh:** Komentar berisi <script> pencuri cookie tereksekusi saat halaman dibuka oleh admin.
- Dampak:** Pencurian sesi/cookie, pengambilalihan akun, dan defacement tampilan.

3 Broken Access Control (IDOR)

OWASP A01: Broken Access Control

Severity: High

- Apa itu:** Pengguna dapat mengakses data atau fungsi milik orang lain hanya dengan mengubah parameter.
- Contoh:** Mengubah /invoice?id=1001 menjadi id=1002 menampilkan tagihan pengguna lain.
- Dampak:** Kebocoran data antar-pengguna dan akses fungsi admin tanpa otorisasi.

4 Autentikasi & Sesi Lemah (Brute Force)

OWASP A07: Identification & Auth Failures

Severity: High

- Apa itu:** Tidak ada pembatasan percobaan login, kebijakan password lemah, atau sesi yang tidak kedaluwarsa.
- Contoh:** Penyerang mencoba ribuan kombinasi password tanpa diblokir (tanpa rate limiting / lockout).
- Dampak:** Pengambilalihan akun secara massal (credential stuffing).

5 Security Misconfiguration

OWASP A05: Security Misconfiguration

Severity: Medium

- Apa itu:** Konfigurasi default dibiarkan, panel admin terbuka, pesan error verbose, atau directory listing aktif.
- Contoh:** Halaman /admin dapat diakses publik; pesan error menampilkan stack trace & versi framework.
- Dampak:** Memberi peta serangan kepada peretas dan akses tak sah ke panel administrasi.

6 Sensitive Data Exposure

OWASP A02: Cryptographic Failures

Severity: High

- Apa itu:** Data sensitif dikirim atau disimpan tanpa enkripsi memadai; rahasia ter-hardcode di kode.
- Contoh:** Situs tanpa HTTPS/HSTS; API key tertanam di dalam file JavaScript front-end.
- Dampak:** Penyadapan data (man-in-the-middle) dan penyalahgunaan kredensial/kunci.

7 Cross-Site Request Forgery (CSRF)

OWASP A01: Broken Access Control

Severity: Medium

Apa itu: Aksi penting dieksekusi tanpa token anti-CSRF, sehingga dapat dipicu dari situs lain.

Contoh: Tautan tersembunyi memicu 'ubah email akun' saat korban yang sedang login mengkliknya.

Dampak: Perubahan data akun atau transaksi atas nama korban tanpa sepengetahuannya.

8 Server-Side Request Forgery (SSRF)

OWASP A10: SSRF

Severity: High

Apa itu: Server dapat dipaksa mengakses URL internal yang dikendalikan oleh penyerang.

Contoh: Fitur 'ambil gambar dari URL' diarahkan ke `http://169.254.169.254/` (metadata cloud).

Dampak: Akses ke layanan internal dan pencurian kredensial cloud.

9 Unrestricted File Upload (Webshell -> RCE)

OWASP A05 / A03

Severity: Critical

Apa itu: Upload file tanpa validasi tipe, sehingga skrip server berbahaya bisa diunggah dan dieksekusi.

Contoh: Mengunggah `shell.php` melalui form 'upload foto profil', lalu mengaksesnya langsung.

Dampak: Eksekusi kode jarak jauh (RCE) dan kendali penuh atas server.

10 Vulnerable & Outdated Components

OWASP A06: Vulnerable Components

Severity: High

Apa itu: Menggunakan library, framework, atau plugin dengan kerentanan yang sudah diketahui publik (CVE).

Contoh: CMS atau plugin versi lama dengan CVE publik yang kode eksploitasinya tersedia bebas.

Dampak: Dieksploitasi otomatis oleh bot dan menjadi pintu masuk awal serangan.

Temukan celah ini sebelum peretas melakukannya.

Hubungi Avangard Security untuk asesmen keamanan aplikasi web Anda.

Email: support@stacopa-avangard.com - Web: stacopa-avangard.com